Informe de evaluación de controles de confidencialidad

E(Tres Patitos, XEPDB1, 23/11/2026) · segunda evaluación · ISO/IEC 27001:2022, Anexo A

Simulación. Este informe se generó con resultados simulados de los scripts de verificación, a solicitud del curso, para mostrar cómo se registra y se compara una evaluación en el tiempo. La empresa Tres Patitos es ficticia: ningún dato proviene de una ejecución real.

Empresa (i)	Tres Patitos
Base de datos (b)	XEPDB1 · Oracle Database 21c Express Edition
Fecha (t)	23/11/2026
Evaluación anterior	23/10/2026 · RC 53,5 % · Amarillo
Auditor	Gloriana Sojo Pereira
Scripts aplicados	01_verificacion_controles.sql (PT-00 a PT-15) · 03_pruebas_funcionales.sql (PF-01 a PF-07) · PF-08 en RMAN

1. Resultado

76,4 %

Semáforo Verde · +22,9 puntos frente al 23/10/2026

Tres Patitos corrigió en un mes la mayoría de los hallazgos de control de acceso, privilegios, enmascaramiento y respaldos. Quedan pendientes la separación de funciones del DBA, el cifrado de red y la revisión periódica de privilegios.

RC(i, b, t) = (CS1·W1 + … + CS15·W15) / (W1 + … + W15). CSk sale del criterio de madurez: 1 si cumple (nivel 3 o 4), 0,5 si es parcial (nivel 2) y 0 si no cumple (nivel 0 o 1). Wk es el puntaje I×P del riesgo más alto que atiende el control.

2. Comparación por control

Control	Antes	Ahora	Estado	Evidencia
M-01 · A5.12 Clasificación de la información	2	2	Parcial	PT-01: 8 de 9 columnas sensibles etiquetadas; falta RRHH.EMPLEADOS.DIRECCION.
M-02 · A5.15 Control de acceso	1	**3**	Cumple	Corregido. PT-02: 0 privilegios directos; se revocó el grant a PUBLIC. PF-03: sin rol, ORA-00942.
M-03 · A5.16 Gestión de identidades	2	**3**	Cumple	Corregido. PT-03: 0 filas; CVARGAS y TEMP_SOPORTE bloqueadas el 27/10/2026.
M-04 · A5.17 Información de autenticación	3	3	Cumple	PT-04: 0 filas. PF-02: ORA-28003, contraseña débil rechazada.
M-05 · A5.18 Derechos de acceso	0	0	No cumple	Pendiente. PT-05: sin captura de privilegios ni acta de revisión (programada para diciembre).
M-06 · A5.33 Protección de registros	1	1	No cumple	Nivel 1: se designó a la responsable de auditoría, pero ADMIN_BD conserva DBA y AUDIT_ADMIN (PT-06, PF-07).

Control	Antes	Ahora	Estado	Evidencia
M-07 · A8.2 Derechos de acceso privilegiado	2	**3**	Cumple	Corregido. PT-07: rol DBA solo en SYSTEM y ADMIN_BD; sin privilegios ANY en cuentas propias.
M-08 · A8.3 Restricción de acceso a la información	3	3	Cumple	PT-08: 2 políticas VPD activas. PF-05: cada usuario ve su departamento.
M-09 · A8.5 Autenticación segura	3	3	Cumple	PT-09: PERFIL_FUNCIONARIO cumple; 0 cuentas DEFAULT. PF-01: ORA-28000.
M-10 · A8.10 Eliminación de información	2	**3**	Cumple	Corregido. PT-10: papelera de FIN purgada; retención RMAN de 14 días.
M-11 · A8.11 Enmascaramiento de datos	2	**3**	Cumple	Corregido. PT-11: 0 columnas sensibles sin redacción; nueva política RED_PAGOS. PF-04: redacción en RRHH y FIN.
M-12 · A8.12 Prevención de fuga de datos	3	3	Cumple	PT-12: keystore OPEN; tablespaces cifrados; exportación solo en cuentas autorizadas.
M-13 · A8.13 Respaldo de la información	2	**3**	Cumple	Corregido. PT-13: respaldo de 22/11 23:51; 0 piezas sin cifrar. PF-08: OK.
M-14 · A8.15 Registro (logging)	3	3	Cumple	PT-14: 3 políticas activas, 3330 eventos en 7 días. PF-06: lecturas registradas.
M-15 · A8.20 Seguridad de redes	0	0	No cumple	Pendiente. PT-15: sin cifrado de red; cambio de sqlnet.ora programado para el 07/12/2026.
RC	53,5 %	**76,4 %**	Verde	

Antes y Ahora: criterio de madurez de 0 a 4. En negrita, los controles que cambiaron.

3. Pendientes y recomendaciones

A5.33 · Separación de funciones (R-CONF-05)

Hallazgo: ADMIN_BD conserva DBA y AUDIT_ADMIN; en PF-07 pudo crear una política de auditoría.
Recomendación: Completar el traspaso de AUDIT_ADMIN a la responsable de auditoría y revocarlo de ADMIN_BD.

A8.20 · Seguridad de redes (R-CONF-02)

Hallazgo: Las conexiones siguen sin cifrar.
Recomendación: Aplicar SQLNET.ENCRYPTION_SERVER = REQUIRED y TCP.VALIDNODE_CHECKING en la ventana del 07/12/2026.

A5.18 · Derechos de acceso (R-CONF-01)

Hallazgo: No hay captura ni acta de revisión de privilegios.
Recomendación: Ejecutar DBMS_PRIVILEGE_CAPTURE durante un ciclo de trabajo y documentar la revisión trimestral.

A5.12 · Clasificación (R-CONF-01, R-CONF-04)

Hallazgo: Falta etiquetar RRHH.EMPLEADOS.DIRECCION.
Recomendación: Etiquetarla y aplicarle redacción.

Si se corrigen los tres primeros, el RC sube a 96,3 %. Ningún control llega todavía al nivel 4, que exige evidencia de revisión periódica.

4. Anexos

• evidencia_verificacion_TresPatitos_XEPDB1_2026-11-23.txt: salida simulada del script, con el resultado de cada prueba.
• evidencia_funcional_TresPatitos_XEPDB1_2026-11-23.txt: salida simulada del script, con el resultado de cada prueba.

Referencias: ISO/IEC 27001:2022; ISO/IEC 27002:2022; Oracle Database 21c Security Guide y Database Reference; Ley 8968 de Protección de la Persona frente al Tratamiento de sus Datos Personales.